SLIIT BSc CYBERSECURITY

CS4020 • LECTURE MODULE

# Social Engineering in Cybersecurity

Exploiting the Human Vector: Attack Anatomy, Real-World Case Studies, Psychological Triggers, and Defense Architectures

---

TARGET AUDIENCE

**BSc Cybersecurity Undergraduates**

LECTURE DURATION

**2 Hours (Theory + Case Studies + Lab)**

MODULE CODE

**CS4020 - Human Factors in Security**

STRUCTURED TIMELINE

# 2-Hour Lecture Agenda

00:00 - 00:30 PART I

### Foundations & Psychology

Human vulnerability metrics, 5-stage lifecycle, and 6 psychological levers.

00:30 - 01:00 PART II

### Attack Vector Taxonomy

Digital spectrum (Phishing, Vishing, Smishing) and physical intrusions (Tailgating, USBs).

01:00 - 01:30 PART III

### Global Real-World Case Studies

Deepfake $25M Heist, Scattered Spider Okta bypass, Toyota BEC, and RSA Spear Phishing.

01:30 - 01:45 PART IV

### Defense & Technical Controls

FIDO2 passkeys, Zero-Trust network rules, DMARC/SPF, and Out-of-Band authentication.

01:45 - 01:55 PART V

### Undergraduate Workshop Scenario

Analyzing malicious email headers and building OOB verification protocol models.

01:55 - 02:00 CLOSE

### Key Takeaways & Q&A

Summary of critical principles and open discussion for SLIIT undergraduates.

01. FOUNDATIONS

# What is Social Engineering?

### Core Definition

Manipulation of human psychology to bypass technical security controls and gain unauthorized enterprise system access.

### The Human Vulnerability Vector

Over 68% of corporate data breaches involve human element exploitation rather than direct zero-day software exploits.

> **"Amateurs hack systems. Professionals hack people." — Kevin Mitnick**



02. ATTACK MECHANICS

# The 5-Stage Attack Lifecycle

1

**Reconnaissance**

OSINT gathering via LinkedIn, social media, and domain records.

2

**Pretexting**

Crafting believable persona (IT help desk, external auditor, CEO).

3

**Engagement**

Initiating contact via email, phone, SMS, or physical entry.

4

**Exploitation**

Victim reveals credentials, runs malicious code, or transfers funds.

5

**Exfiltration**

Lateral movement, privilege escalation, and erasing log trails.

03. PSYCHOLOGY

# Key Psychological Levers

### Authority

Impersonating C-suite executives, law enforcement, or regulatory compliance auditors.

### Urgency

Creating artificial 15-minute deadlines to suppress logical critical thinking.

### Fear & Intimidation

Threatening account suspension, legal lawsuits, or corporate disciplinary action.

### Curiosity

Baiting with executive salary files, bonus lists, or confidential restructure plans.

### Helpfulness

Exploiting standard employee helpfulness to resolve fake IT connectivity issues.

### Greed / Quid Pro Quo

Promising free gift cards, software licenses, or cash rewards in exchange for credentials.

04. ATTACK VECTORS

# Digital Social Engineering Spectrum



### Phishing

Mass deceptive emails impersonating trusted brands to harvest user logins.



### Vishing

Voice phone calls impersonating IT help desk personnel or banking security agents.




### Smishing

Urgent SMS text messages containing shortened URLs linking to malicious portals.



### Quishing

Malicious QR codes bypassing traditional email security gateways to steal tokens.

05. PHYSICAL DOMAIN

# Physical Social Engineering

### Tailgating / Piggybacking

Following authorized personnel into server rooms by exploiting politeness holding doors open.

### Baiting (USB Drops)

Leaving malware-loaded USB flash drives labeled "Executive Salaries 2026" in corporate parking lots.

### Shoulder Surfing

Observing passcodes and confidential screen data in public spaces like cafes and airports.

### Dumpster Diving

Rummaging through corporate waste bins to discover unshredded org charts and passwords.

CASE STUDY 01 • AI DEEPFAKE FRAUD

# The $25M AI Deepfake Video Call Heist

**INCIDENT SUMMARY**

Hong Kong finance employee tricked into transferring $25 Million USD after joining a video conference with AI-cloned executives.

### Tactical Mechanics

Attackers reconstructed CFO voice and video from public media clips, generating full real-time interactive avatars on Zoom.

### Key Takeaway for Engineers

Visual and acoustic confirmation alone are no longer sufficient proof of identity for high-value financial transactions.



CASE STUDY 02 • IDENTITY & MFA BYPASS

# Scattered Spider: Help Desk Vishing




**Attack Technique**

Threat actors call internal IT help desks posing as employees requesting password resets and MFA device re-registration.

**Impact & Fallout**

Bypassed Okta SSO and multi-factor authentication, causing over $300 Million USD in downtime across major retail networks.

**Core Vulnerability**

Help desk staff lacked strict out-of-band identity verification processes during credential reset procedures.

CASE STUDY 03 • FINANCIAL WIRE FRAUD

# Business Email Compromise (BEC): Toyota Boshoku

**$37 MILLION LOSS**

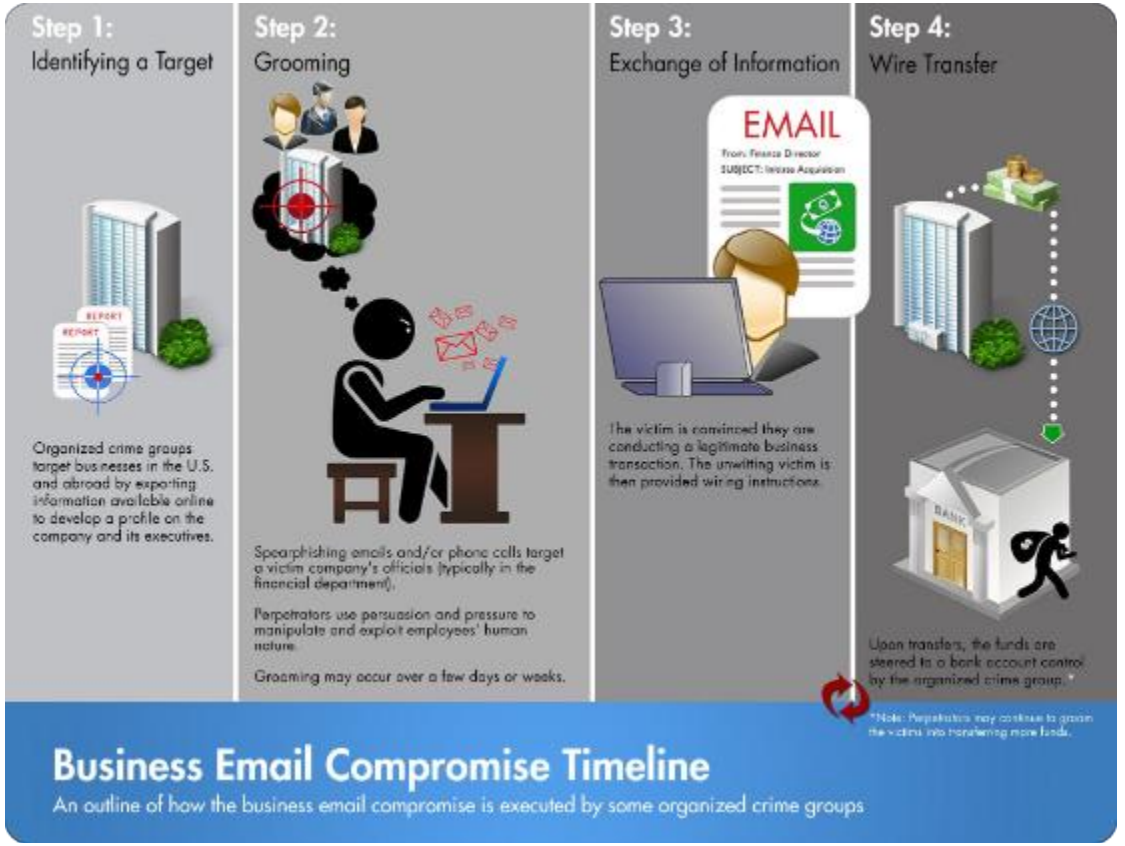
Attackers spoofed executive email correspondence to convince finance staff to alter supplier bank account details.

### Pretexting & Email Hijacking

Lookalike domain spoofing coupled with compromised legitimate vendor email accounts during active payment cycles.

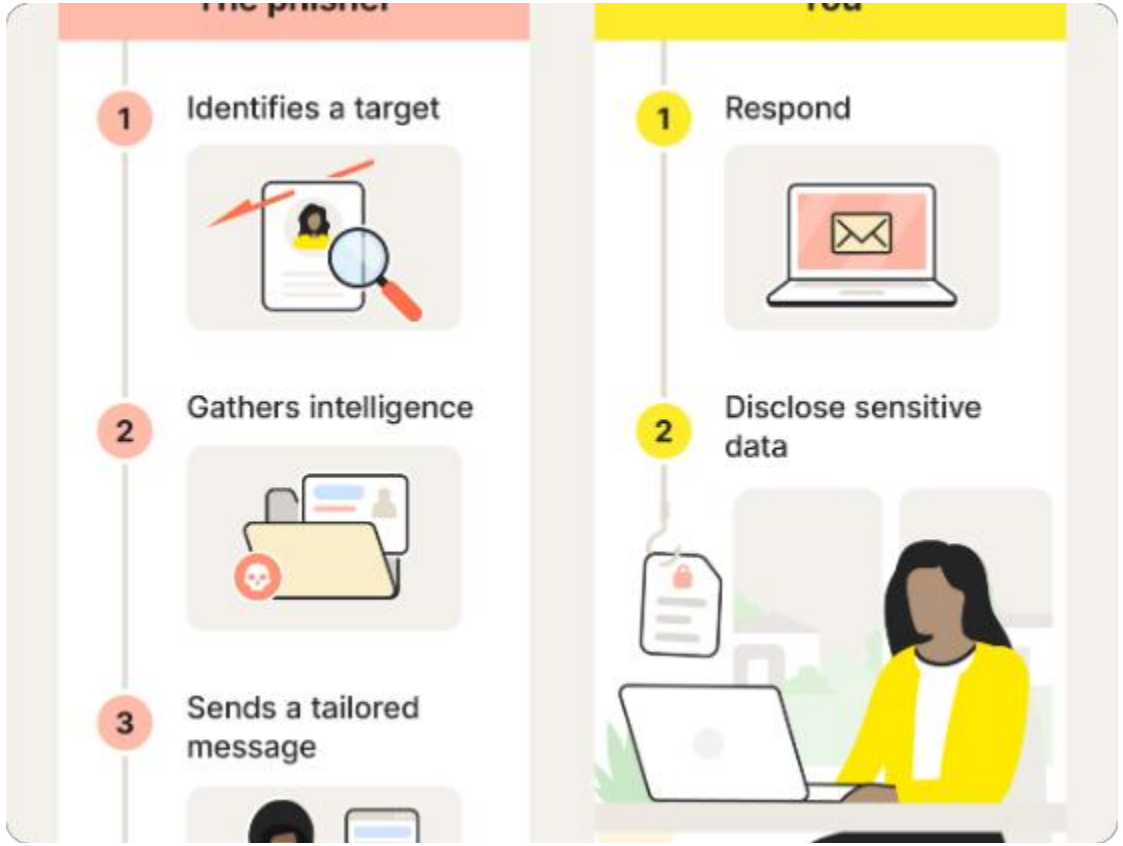
### Systemic Failure

Absence of dual-signoff authorization rules for modifying banking details in Enterprise Resource Planning (ERP) systems.



CASE STUDY 04 • APT CRITICAL BREACH

# RSA SecurID & OAuth Consent Phishing




**RSA SecurID Incident (2011)**

Spear-phishing email titled "2011 Recruitment Plan" sent to low-level employees contained Flash zero-day, compromising 2FA seed keys globally.

**OAuth Consent Grant Phishing (Modern)**

Tricking users into clicking "Authorize App" in Microsoft 365, granting attackers persistent API access without stealing passwords.

**Lesson for Undergraduates**

Modern attackers target authentication tokens and API scopes, rendering traditional password changes ineffective.

ADVANCED THREAT VECTORS

# Watering Hole Attacks & Web Compromise

**1. Profile Target Group**

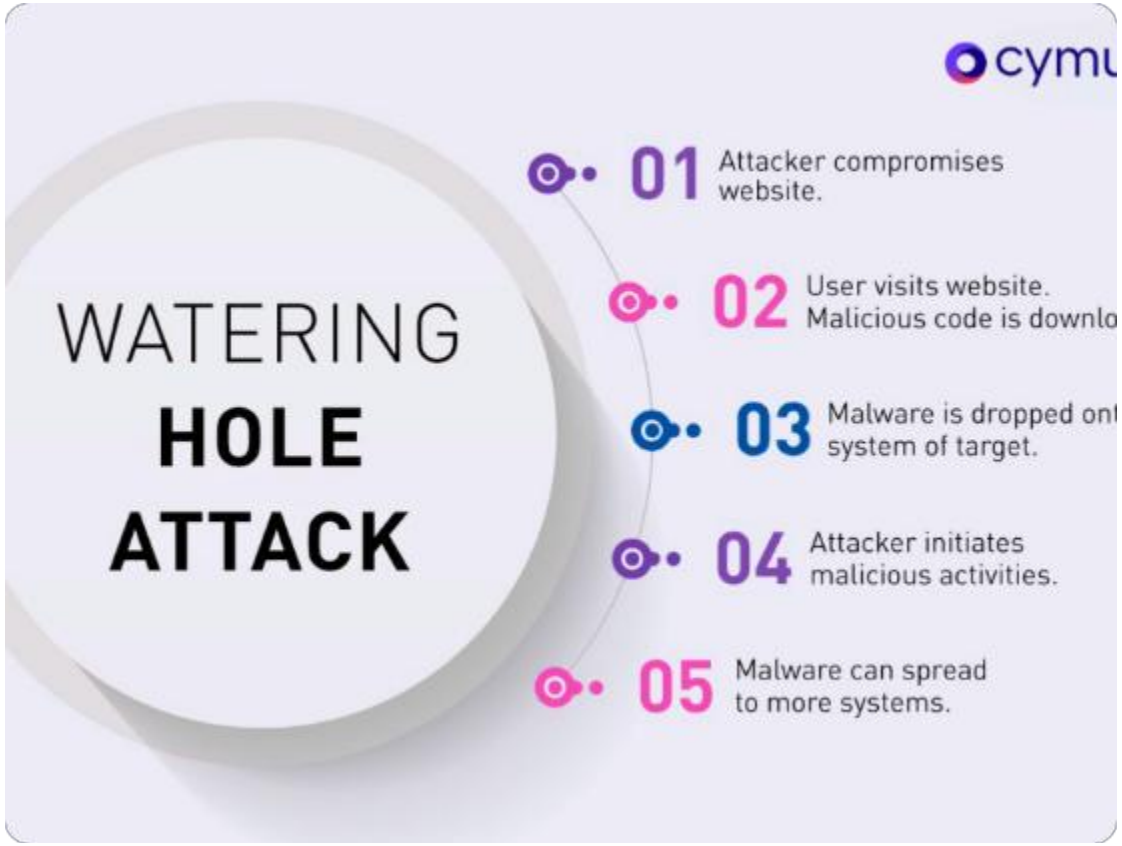
Identify websites frequently visited by target organization employees (e.g., industry forums, regional portals).

**2. Inject Drive-by Exploits**

Compromise the target website to serve zero-day browser exploits or fake browser update prompts.

**3. Silent Endpoint Compromise**

Victim visits legitimate trusted site; malware executes automatically without active user click.



06. NEXT-GEN THREATS

# Emerging AI & Automated Vectors

### LLM Spear Phishing

Generative AI models craft hyper-personalized phishing emails devoid of traditional grammatical errors or typos.

### Real-Time Voice Cloning

Synthesizing executive voice patterns from 3-second audio samples to execute urgent vishing requests.

### MFA Fatigue (Prompt Bombing)

**100+ Push Alerts**

Flooding user smartphones with repeated authentication requests until the victim clicks "Approve".

07. DEFENSIVE STRATEGY

# Defense-in-Depth Framework

**1. FIDO2 / Passkey Hardware Keys**

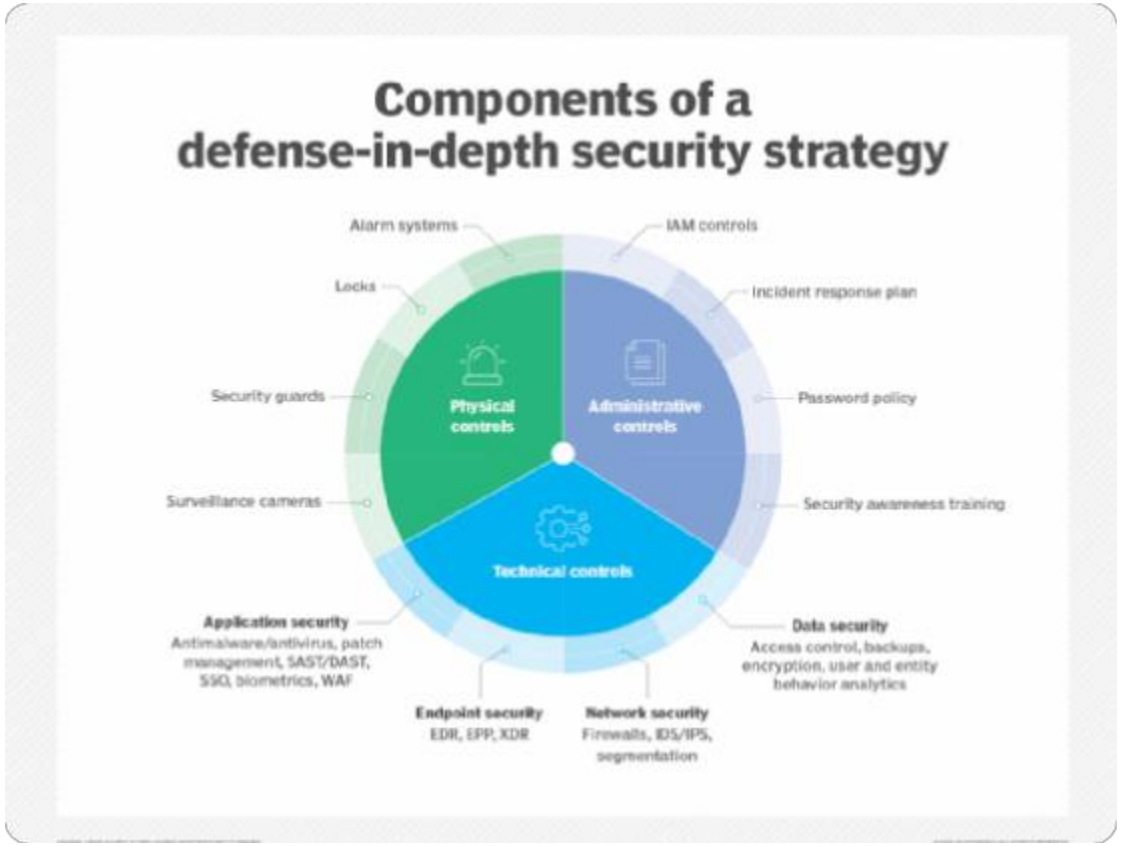
Phishing-resistant authentication stopping credential harvesting and OTP theft completely.

**2. Out-of-Band (OOB) Verification**

Mandatory secondary channel confirmation for high-risk requests and password resets.

**3. Zero-Trust Access Control**

Least-privilege policy limiting blast radius if an individual account gets compromised.



# Social Engineering Countermeasure Matrix

| Attack Type | Exploited Vulnerability | Technical Mitigation | Process Control |
|---|---|---|---|
| **Phishing / Email** | Domain trust bias | DMARC, DKIM, SPF enforcement | External email banner tags |
| **Help Desk Vishing** | Employee helpfulness | FIDO2 WebAuthn hardware keys | Manager callback verification |
| **Deepfake Audio/Video** | Sensory trust (seeing/hearing) | Acoustic watermark detection | Dual-authorization wire rules |
| **Tailgating** | Social courtesy | Anti-passback turnstiles | Visitor escort mandates |

# Lab Exercise & Student Q&A

## 🧪 10-Minute Student Lab Scenario

**Task:** You are the SOC Lead at SLIIT. Design a 3-step Out-of-Band (OOB) identity verification workflow for helpdesk credential resets that resists Scattered Spider style vishing attacks.

## 💬 Key Discussion Questions

1. Why does traditional SMS/Email MFA fail against modern Adversary-in-the-Middle (AiTM) phishing?
2. How can organizations balance security protocols against operational friction for remote staff?

# Image Sources



https://www.techbrain.com.au/wp-content/uploads/2023/06/combatting-social-engineering-4.jpg

Source: www.techbrain.com.au

---



https://purplesec.us/wp-content/uploads/2026/01/Arup-deepfake-attack-and-financial-cyber-fraud.png

Source: purplesec.us

---



https://www.fastpasscorp.com/wp-content/uploads/2026/03/2Scattered-Spider-1k-Women-Vishing-Blog.jpg

Source: www.fastpasscorp.com

---



https://www.fbi.gov/image-repository/business-email-compromise-timeline-050222.jpg

Source: www.fbi.gov

---



https://uk.norton.com/content/dam/blogs/images/norton/am/spear-phishing-01-upd.png

Source: uk.norton.com

---




https://cymulate.com/uploaded-files/2021/02/Untitled-design-1-1024x621.png

Source: cymulate.com

# Image Sources



https://cdn.ttgtmedia.com/rms/onlineimages/apparch-defense_in_depth_layers-f_mobile.png

Source: www.techtarget.com